Fairway Accounting Group

Cybersecurity Incident Response Plan

Document Type: Proposed Security Policy
Prepared For: Fairway Accounting Group
Framework: NIST Cybersecurity Framework 2.0
Status: Proposed — Not Yet Implemented Company-Wide

1. Purpose

The purpose of this Incident Response Plan is to establish a clear process for identifying, reporting, investigating, and responding to cybersecurity incidents at Fairway Accounting Group.

As an accounting firm, Fairway handles sensitive financial records, payroll information, tax documents, and personal client information. A security incident involving this data could interrupt business operations, expose confidential records, and damage client trust.

This plan is designed to help employees and the IT/Security team respond to incidents quickly while reducing unnecessary disruption to the business.

2. Scope

This plan applies to Fairway employees, company-owned devices, internal servers, user accounts, shared files, and systems used to store or process client information.

Examples of incidents covered by this plan include:

- Phishing emails and suspected account compromise
- Malware or ransomware infections
- Unauthorized access to sensitive files
- Suspicious login attempts
- Lost or stolen company devices
- Accidental exposure of confidential information
- Unexpected changes to important systems

Employees should report suspicious activity even when they are unsure whether an actual security incident has occurred.

3. Roles and Responsibilities

Role	Responsibility
IT/Security Team	Investigate alerts, collect evidence, contain threats, and restore systems
IT/Security Lead	Coordinate the response, document decisions, and provide updates
Management	Approve major business decisions and coordinate outside assistance
HR/Operations	Assist with employee-related incidents and internal communication
Employees	Report suspicious activity and follow IT/Security instructions
External Specialists	Provide technical, legal, or forensic assistance when necessary

Because Fairway is a small business, some employees may perform more than one response role.

4. Incident Response Procedures

4.1 Preparation

Before an incident occurs, Fairway should maintain updated security policies, backups, endpoint protection, firewall rules, and centralized monitoring.

The IT/Security team should keep an inventory of important systems and maintain contact information for management, service providers, and emergency support.

Employees should receive basic security awareness training, including how to recognize phishing attempts and report suspicious activity.

4.2 Detection and Analysis

Security incidents may be identified through employee reports, Windows security logs, Wazuh alerts, endpoint protection, or unusual network activity.

When suspicious activity is reported, the IT/Security team should:

1. Record the date, time, affected systems, and initial observations.
2. Review available logs and alerts.
3. Determine whether the activity is expected, suspicious, or confirmed malicious.
4. Identify which accounts, devices, and information may be affected.
5. Assign a priority based on the possible impact.

Incidents involving sensitive client information, administrator accounts, or major business disruption should receive immediate attention.

4.3 Containment

Once an incident is confirmed, the IT/Security team should take steps to prevent it from spreading.

Depending on the situation, containment may include disconnecting an infected workstation, disabling a compromised account, blocking suspicious network traffic, or restricting access to affected systems.

The team should preserve relevant logs and evidence before making major changes whenever it is safe to do so.

Management should be informed when containment actions could significantly affect business operations.

4.4 Eradication and Recovery

After the immediate threat is contained, the IT/Security team should identify and remove the cause of the incident.

This may involve removing malware, correcting insecure settings, resetting passwords, installing security updates, or rebuilding affected systems.

Systems should only return to normal operation after the team has checked that the threat has been addressed.

If data restoration is necessary, backups should be verified before use. Restored systems should be monitored for signs of continued suspicious activity.

4.5 Lessons Learned

After an incident is resolved, the IT/Security team should document what happened, how it was detected, what actions were taken, and whether the response was effective.

The team should identify any security gaps that contributed to the incident and recommend changes to reduce the likelihood of similar problems.

Important lessons should be shared with management and used to improve security policies, employee training, and technical controls.

5. Incident Severity Levels

Severity	Description	Example
Low	Suspicious activity with limited impact	A small number of unsuccessful login attempts
Medium	Potential compromise requiring investigation	Malware detected on one workstation
High	Confirmed compromise involving important systems or sensitive information	Unauthorized access to Payroll files
Critical	Major incident affecting multiple systems or business operations	Ransomware spreading across company servers

The IT/Security Lead should determine the severity using the available evidence and update it if new information becomes available.

6. Communication and Reporting

Employees should report suspected incidents directly to the IT/Security team through an approved company communication channel.

The IT/Security Lead should document the incident and notify management when sensitive information, important systems, or business operations may be affected.

If client information is exposed, management should work with qualified legal and compliance professionals to determine applicable notification requirements.

Employees should not independently contact affected clients or publicly discuss incident details unless authorized.

7. Testing and Maintenance

Fairway should review this plan at least once per year and whenever major systems or business operations change.

The company should also conduct periodic incident-response exercises to confirm that employees understand their responsibilities.

During the capstone project, a controlled failed-login simulation demonstrated that Wazuh could detect Windows authentication failures. This provided initial evidence of monitoring capabilities but did not represent a complete test of this response plan.

Future exercises should include phishing, ransomware, compromised accounts, and backup recovery scenarios.

8. Conclusion

This Incident Response Plan provides Fairway Accounting Group with a starting point for handling cybersecurity incidents in an organized manner.

The plan is intended to reduce confusion during an incident, protect sensitive client information, and help restore business operations safely.

Before adopting the plan, Fairway should assign specific personnel to response roles, confirm reporting channels, establish escalation contacts, and test the procedures through regular exercises.